

DEVSECOPS QUALITY ASSESSMENT

Repository Quality Rating & Agentic AI Transformation



An evidence-based quality rating of skondla/fastAPIWebApp across DevSecOps, infrastructure and pipeline automation — and a roadmap to transform it with Agentic AI.

DevSecOps

Infrastructure

Pipeline Automation

Agentic AI

From a quality rating to an AI-transformed pipeline

01

The repository at a glance

What fastAPIWebApp is, and how it is delivered.



02

How we rate quality

Three domains, scored 1–5 against observed evidence.



03

Quality scorecard

The headline rating across all three domains.



04

DevSecOps quality

Scanning, enforcement, secrets and supply chain.



05

Infrastructure quality

IaC, multi-cloud parity and Kubernetes hardening.



06

Pipeline automation quality

Stage design, orchestration and gate enforcement.



07

The Agentic AI opportunity

Where autonomous agents lift this repository.



08

AI transformation & next steps

A phased roadmap, guardrails and recommendations.



The repository at a glance

A multi-cloud, containerized FastAPI web application and REST API for Amazon RDS operations, delivered through a complete DevSecOps pipeline as a reference implementation.



Application

Two FastAPI services — USER & ADMIN, Python 3.11 on Uvicorn



Delivery

Six GitHub Actions DevSecOps workflows, one per app × cloud



Targets

Kubernetes on AWS EKS, GCP GKE and Azure AKS



Infrastructure

Modular Terraform; Prometheus, Grafana and RabbitMQ operators



Security

Six scanners — secret, SAST, SCA, image, IaC and DAST



Function

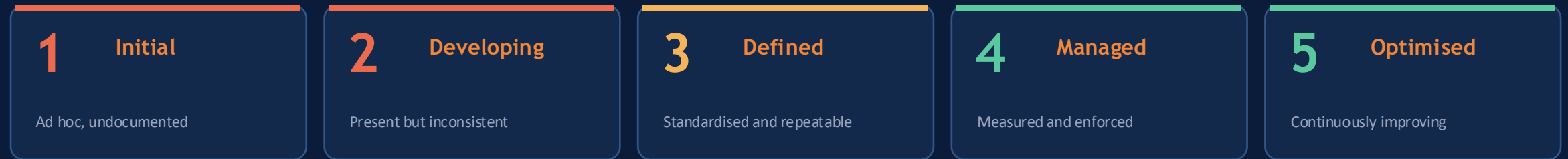
Authenticated RDS restore, status and attach operations

METHOD

How we rate quality

Three domains, each scored 1 to 5 against observed evidence in the repository — the same maturity ladder applied consistently.

THE FIVE-LEVEL SCALE

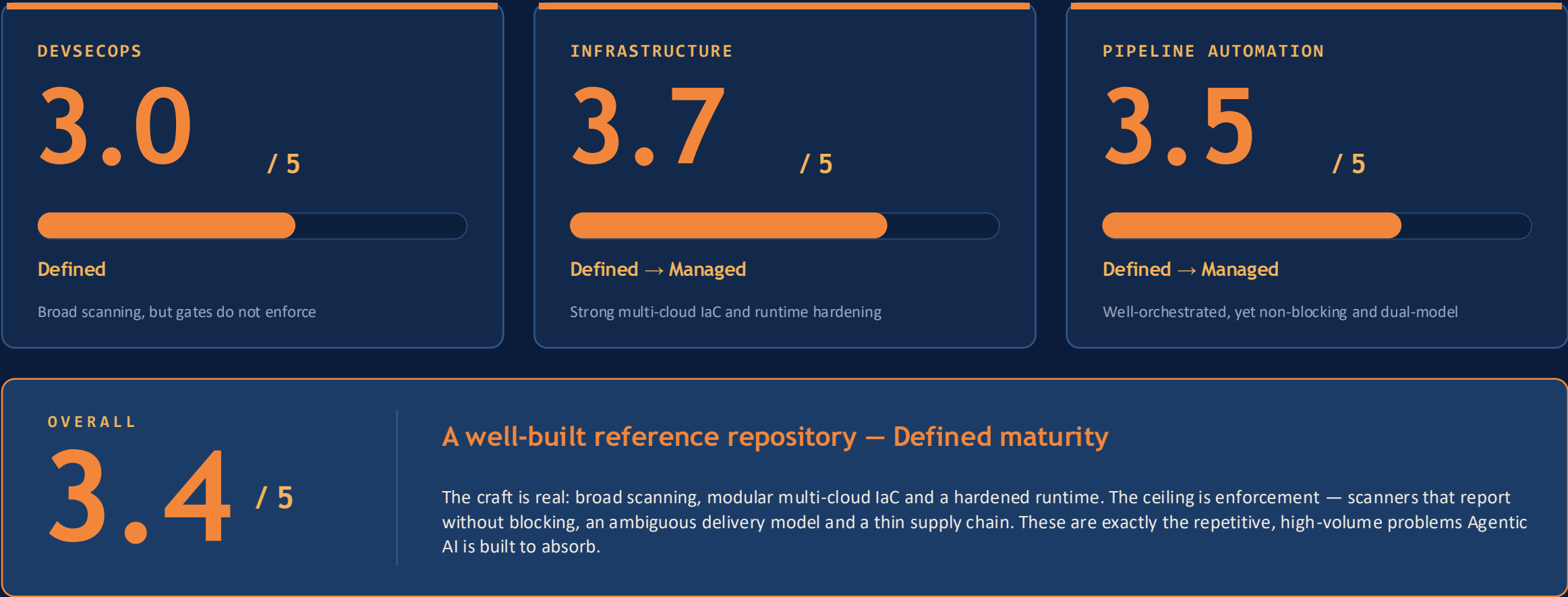


WHAT EACH DOMAIN MEASURES



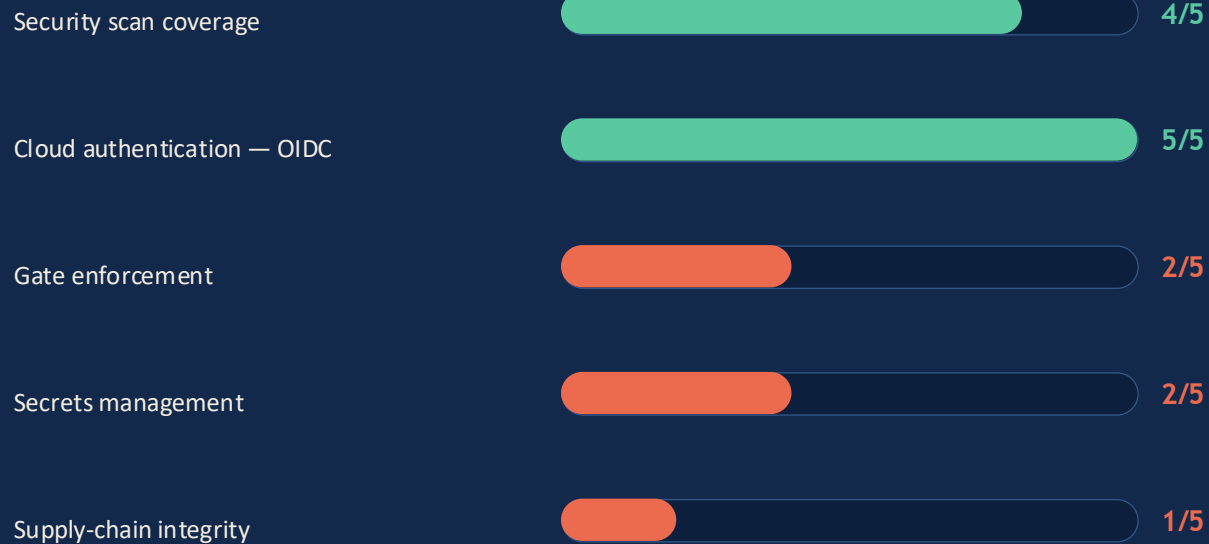
The headline rating

Three domains scored against the evidence — and a weighted overall rating for the repository.



DevSecOps quality — 3.0 / 5

RATING CRITERIA



DOMAIN SCORE

3.0 / 5

Defined — capable, not yet enforced

WHAT LIFTS THE SCORE

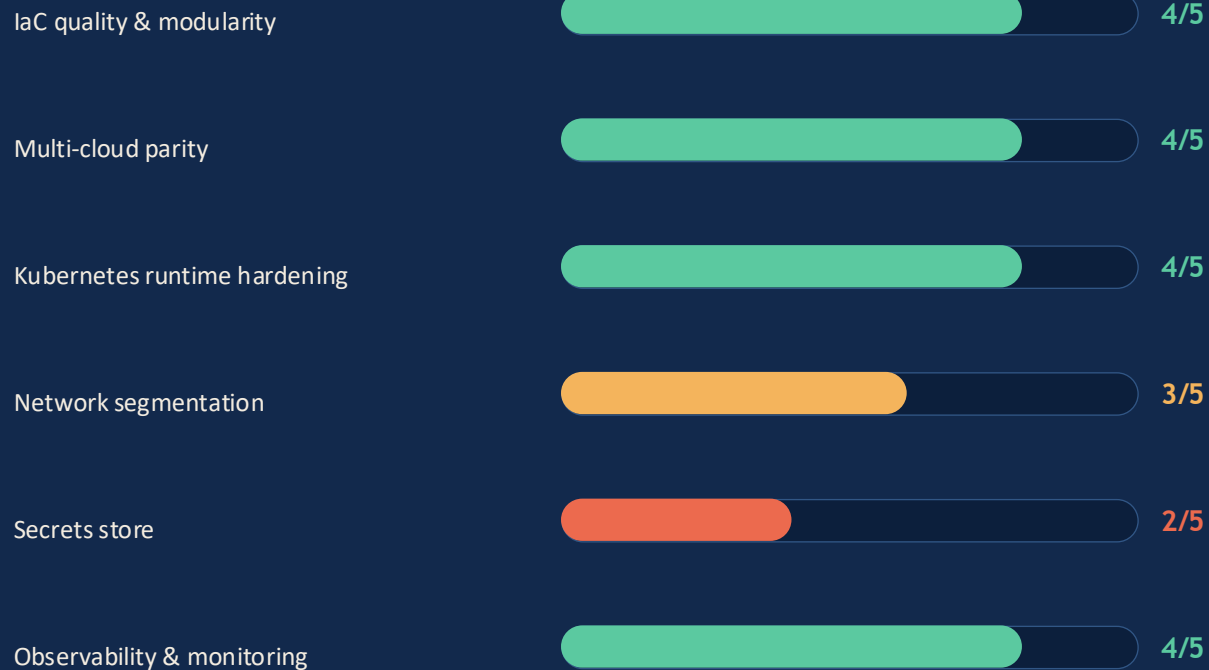
- Six scanners span the full delivery lifecycle
- Keyless OIDC federation — no static cloud keys
- Findings centralised as SARIF in one place

WHAT HOLDS IT BACK

- Every gate is non-blocking — visibility only
- Secrets held in a plain base64 Kubernetes Secret
- No image signing, SBOM or provenance

Infrastructure quality — 3.7 / 5

RATING CRITERIA



DOMAIN SCORE

3.7 / 5

Defined → Managed — strong, with gaps

WHAT LIFTS THE SCORE

- Modular, reusable Terraform across three clouds
- Hardened pods — non-root, seccomp, dropped caps
- Prometheus / Grafana observability in place

WHAT HOLDS IT BACK

- No NetworkPolicy or Pod Security baseline evidenced
- Writable root filesystem on workloads
- Runtime secrets not in a managed store

Pipeline automation quality — 3.5 / 5

RATING CRITERIA



DOMAIN SCORE

3.5 / 5

Defined → Managed — well-orchestrated

WHAT LIFTS THE SCORE

- Nine well-sequenced stages with clean parallelism
- Path-filtered triggers; build-once, promote
- OIDC keyless auth across every workflow

WHAT HOLDS IT BACK

- Scanners run but cannot fail the build
- kubectl apply and ArgoCD both apply state
- No workflow concurrency guard

Where the repository stands

Strong engineering craft across all three domains — held one full level below its potential by a single theme: automation that observes but does not enforce.



3.0

DevSecOps

Broad coverage, zero enforcement



3.7

Infrastructure

Solid IaC; runtime gaps remain



3.5

Pipeline automation

Orchestrated, but non-blocking

THE TAKEAWAY

The fastest route from 3.4 to 4.5 is not more tooling

Every domain loses points in the same place — the volume of findings, configuration checks and pipeline events is larger than a team can triage and act on by hand, so gates are left open and fixes lag. That is a throughput problem. The next section shows how Agentic AI absorbs that load and makes enforcement, remediation and hardening continuous rather than aspirational.

PART TWO

Agentic AI Transformation

How autonomous AI agents turn this repository's reporting pipeline into an enforcing, self-remediating one — the opportunity, a target architecture, the agents to deploy, a phased roadmap and the guardrails that keep it safe.



Why Agentic AI fits this repository

Agentic AI is not a copilot that suggests — it is a system of goal-driven agents that observe, decide and act within guardrails. This repository's gaps are precisely the kind of work agents absorb.



Findings outpace the team

Six scanners produce more findings than anyone can triage — so gates stay non-blocking.

→ *Agents triage, deduplicate and prioritise continuously.*



Remediation is manual

Each CVE, misconfig and IaC gap is a hand-written fix — slow and easily deferred.

→ *Agents open tested fix-PRs the moment an issue appears.*



Hardening drifts

NetworkPolicy, secrets and parity gaps persist because no one owns the steady-state.

→ *Agents watch desired state and propose corrections.*



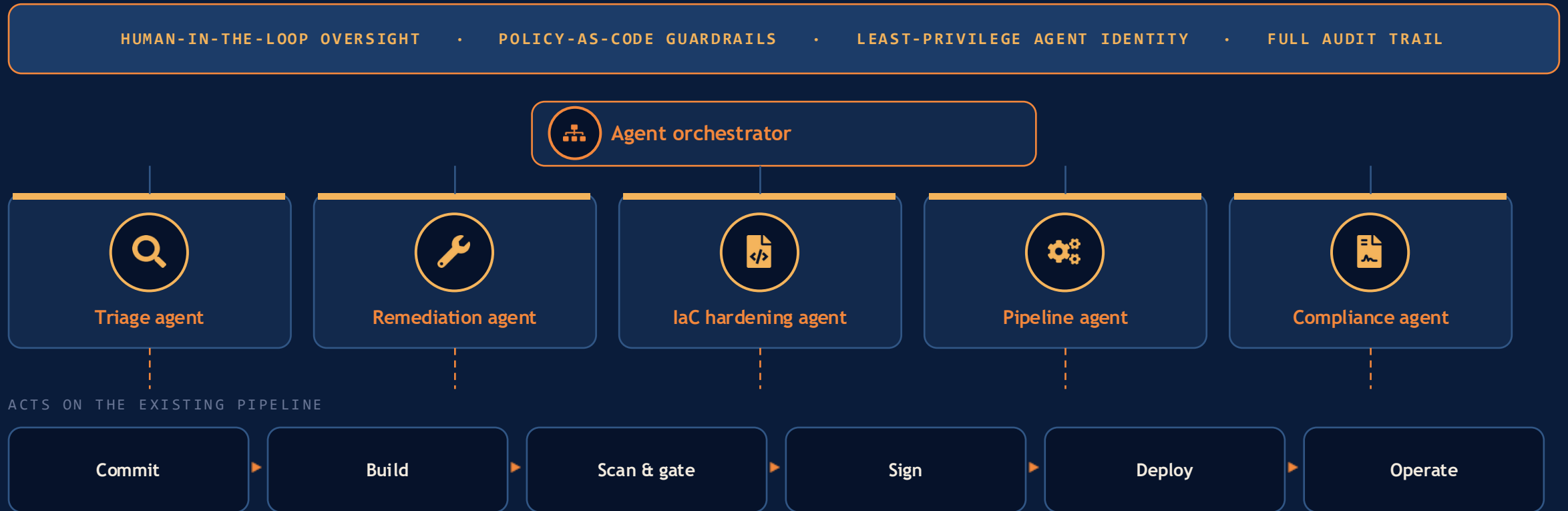
Enforcement feels risky

Blocking the build is feared because the backlog is unknown and unmanaged.

→ *Agents clear the backlog, making enforcement safe to switch on.*

The agent-augmented DevSecOps pipeline

Agents sit beside the existing pipeline — never replacing it — coordinated by an orchestrator and bounded by a human-oversight and policy layer.



Agents observe pipeline events and cluster state, then act — opening PRs, proposing policy, fixing runs — while every consequential change routes back through the human-oversight layer.

Six agents to deploy — and what each does



Security triage agent

Consumes SARIF from all six scanners; deduplicates, ranks by exploitability and reachability, suppresses false positives, files only what matters.



Remediation agent

Opens tested fix-PRs for dependency CVEs and IaC misconfigurations — upgrades, patches, resolves breakage, runs the suite.



Pipeline self-healing agent

Diagnoses failed CI runs — flaky test, real break or infra — then retries, quarantines or proposes a fix automatically.



IaC hardening agent

Watches Terraform and manifests; proposes NetworkPolicy, read-only root filesystem and secrets-store moves, keeping clouds in parity.



Policy & secrets agent

Generates policy-as-code from intent, drafts admission rules, and migrates plaintext secrets to a managed store.



Compliance evidence agent

Continuously assembles SBOMs, scan results and attestations into audit-ready evidence mapped to a framework.

A phased path to an agent-run pipeline

Autonomy is earned in stages — each phase widens what agents may do only after the previous phase has proven safe.



PHASE 1 • 0-2 MONTHS

Assistive

- AI copilots in the IDE and pull-request review
- Triage agent ranks findings — humans still act
- Every change stays human-authored and approved



PHASE 2 • 2-5 MONTHS

Supervised agents

- Agents open fix-PRs and propose IaC and policy
- Pipeline agent self-heals failed runs
- Humans review and approve every merge



PHASE 3 • 5-10 MONTHS

Autonomous + guardrails

- Low-risk fixes auto-merge once tests and policy pass
- Gates enforce; the backlog is agent-managed
- Humans handle exceptions and set policy only

What the AI transformation is projected to move

Indicative targets for an agent-augmented pipeline. Grey is today; orange is the projected steady state after Phase 2.



Guardrails — operating agents safely

Autonomy without bounds is a new attack surface. Each agent runs inside controls that make its actions reviewable, reversible and constrained.



Human-in-the-loop

Every high-risk action — merges, policy changes, production deploys — needs explicit human approval.



Least-privilege identity

Each agent has its own scoped, short-lived credential — never a shared, broad one.



Agents cannot weaken security

An agent may never disable a gate, lower a policy or bypass a control — enforced by policy.



Full audit trail

Every observation, decision and action is logged, attributable and replayable.



Prompt-injection defense

Untrusted scan output and tickets are treated as data — never as instructions to the agent.



Cost & rate limits

Token budgets, action quotas and circuit-breakers stop runaway loops before they spread.

Recommendations — fix the base, then transform

Two tracks run in parallel: close the quality gaps by hand now, while standing up the agents that will keep them closed.



NOW • WEEKS

Fix the fundamentals

- Make scanners block on High / Critical findings
- Move secrets to a managed store via the CSI driver
- Choose one delivery model — ArgoCD as sole applier
- Add image signing, SBOM and a NetworkPolicy baseline



NEXT • 1-3 MONTHS

Stand up supervised agents

- Deploy the triage agent on the scanner output
- Add the remediation agent for CVEs and IaC fixes
- Pilot the pipeline self-healing agent in CI
- Wire every agent into the guardrail layer



STRATEGIC • 3-10 MONTHS

Scale the transformation

- Let low-risk fixes auto-merge under policy
- Add IaC-hardening and compliance-evidence agents
- Track the impact metrics; widen autonomy on evidence
- Re-rate the repository — target 4.5+ across domains

Five things to carry forward

1



A well-built repository — rated 3.4 / 5

Strong craft across all three domains, held back by enforcement, not engineering.

2



Coverage is not protection

Six scanners that cannot fail a build measure risk without reducing it.

3



The gaps are a throughput problem

Findings, fixes and drift outrun the team — exactly the load Agentic AI absorbs.

4



Earn autonomy in phases

Assistive, then supervised, then autonomous — each stage proven before the next.

5



Guardrails are non-negotiable

Human oversight, least privilege and audit trails make agent autonomy safe to grant.